Упрощенная авторизация. Предварительный процесс

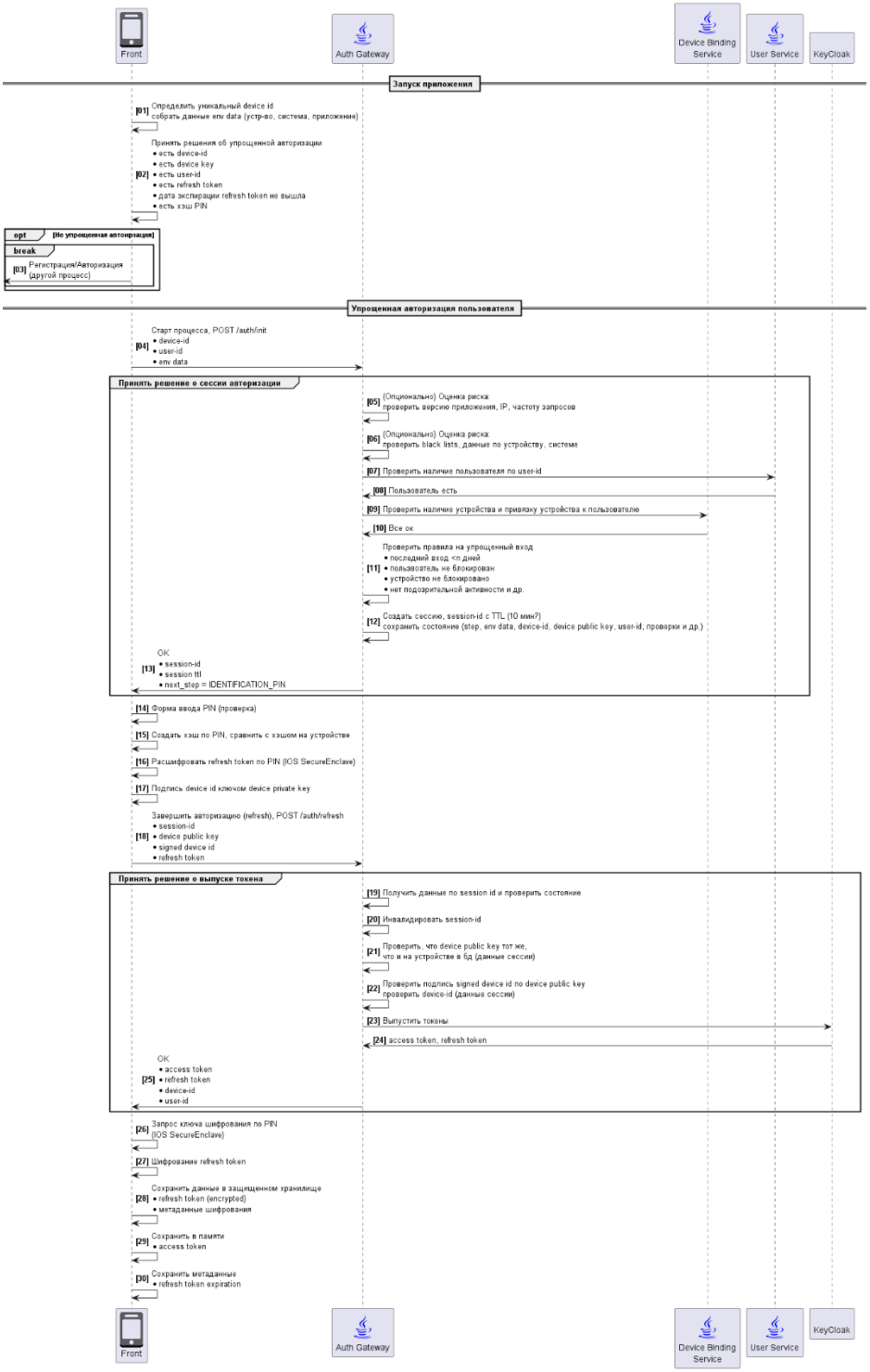
Сценарии:

- авторизация пользователя в установленном приложении, пользователь уже входил ранее (смены пользователей не было)

Plant UML

```
@startuml

!include <tupadr3/devicons/java>
!include <aws/General/mobileclient/mobileclient>
!include <tupadr3/devicons/database>
!include <tupadr3/devicons/codepen>
!include <tupadr3/devicons/redis>

participant "<$mobileclient>\nFront" as frontend
participant "<font color=blue><$java>\nAuth Gateway" as auth
participant "<font color=blue><$java>\nDevice Binding\nService" as device
participant "<font color=blue><$java>\nUser Service" as user
participant "<font color=blue>\nKeyCloak" as idp

autonumber "<b>[00]"
== Запуск приложения ==

  frontend -> frontend: Определить уникальный device id\nсобрать данные env
data (устр-во, система, приложение)

  frontend -> frontend: Принять решения об упрощенной авторизации\n*есть
device-id\n*есть device key\n*есть user-id\n*есть refresh token\n*дата
экспирации refresh token не вышла\n*есть хэш PIN

  opt Не упрощенная автоирзация
    break
      frontend ->[:Регистрация/Авторизация\n(другой процесс)
    end break
  end opt

== Упрощенная авторизация пользователя ==

  frontend -> auth: Старт процесса, POST /auth/init\n*device-id\n*user-
id\n*env data
  group Принять решение о сессии авторизации
    auth -> auth: (Опционально) Оценка риска: \nпроверить версию приложения,
IP, частоту запросов
    auth -> auth: (Опционально) Оценка риска: \nпроверить black lists, данные
по устройству, системе

    auth -> user: Проверить наличие пользователя по user-id
```

```
    user -> auth: Пользователь есть

    auth -> device: Проверить наличие устройства и привязку устройства к
пользователю
    device -> auth: Все ок

    auth -> auth: Проверить правила на упрощенный вход\n*последний вход <n
дней\n*пользвоатель не блокирован\n*устройство не блокировано\n*нет
подозрительной активности и др.

    auth -> auth: Создать сессию, session-id с TTL (10 мин?)\nсохранить
состояние (step, env data, device-id, device public key, user-id, проверки и
др.)

    auth -> frontend: OK\n*session-id\n*session ttl\n*next_step =
IDENTIFICATION_PIN
  end

  frontend -> frontend: Форма ввода PIN (проверка)
  frontend -> frontend: Создать хэш по PIN, сравнить с хэшом на устройстве
  frontend -> frontend: Расшифровать refresh token по PIN (IOS SecureEnclave)
  frontend -> frontend: Подпись device id ключом device private key

  frontend -> auth: Завершить авторизацию (refresh), POST
/auth/refresh\n*session-id\n*device public key\n*signed device id\n*refresh
token
  group Принять решение о выпуске токена
    auth -> auth: Получить данные по session id и проверить состояние

    auth -> auth: Инвалидировать session-id

    auth -> auth: Проверить, что device public key тот же,\nчто и на
устройстве в бд (данные сессии)
    auth -> auth: Проверить подпись signed device id по device public
key\nпроверить device-id (данные сессии)

    auth -> idp: Выпустить токены
    idp -> auth: access token, refresh token

    auth -> frontend: OK\n*access token\n*refresh token\n*device-id\n*user-id

  end

  frontend -> frontend: Запрос ключа шифрования по PIN\n(IOS SecureEnclave)
  frontend -> frontend: Шифрование refresh token
  frontend -> frontend: Сохранить данные в защищенном хранилище\n*refresh
token (encrypted)\n*метаданные шифрования
  frontend -> frontend: Сохранить в памяти\n*access token
  frontend -> frontend: Сохранить метаданные\n*refresh token expiration

@enduml
```


Front
Auth Gateway
Device Binding Service
User Service
KeyCloak
Запуск приложения
[01] Определить уникальный device id
собрать данные env data (устр-во, система, приложение)
Принять решения об упрощенной авторизации
• есть device-id
• есть device key
[02] • есть user-id
• есть refresh token
• дата экспирации refresh token не вышла
• есть хэш PIN
opt [Не упрощенная авторизация]
break
[03] Регистрация/Авторизация (другой процесс)
Упрощенная авторизация пользователя
Старт процесса, POST /auth/init
[04] • device-id
• user-id
• env data
Принять решение о сессии авторизации
[05] (Опционально) Оценка риска:
проверить версию приложения, IP, частоту запросов
[06] (Опционально) Оценка риска:
проверить black lists, данные по устройству, системе
[07] Проверить наличие пользователя по user-id
[08] Пользователь есть
[09] Проверить наличие устройства и привязку устройства к пользователю
[10] Все ок
Проверить правила на упрощенный вход
• последний вход <n дней
[11] • пользователь не блокирован
• устройство не блокировано
• нет подозрительной активности и др.
[12] Создать сессию, session-id с TTL (10 мин?)
сохранить состояние (step, env data, device-id, device public key, user-id, проверки и др.)
OK
[13] • session-id
• session ttl
• next_step = IDENTIFICATION_PIN
[14] Форма ввода PIN (проверка)
[15] Создать хэш по PIN, сравнить с хэшом на устройстве
[16] Расшифровать refresh token по PIN (IOS SecureEnclave)
[17] Подпись device id ключом device private key
Завершить авторизацию (refresh), POST /auth/refresh
• session-id
[18] • device public key
• signed device id
• refresh token
Принять решение о выпуске токена
[19] Получить данные по session id и проверить состояние
[20] Инвалидировать session-id
[21] Проверить, что device public key тот же,
что и на устройстве в бд (данные сессии)
[22] Проверить подпись signed device id по device public key
проверить device-id (данные сессии)
[23] Выпустить токены
[24] access token, refresh token
OK
• access token
[25] • refresh token
• device-id
• user-id
[26] Запрос ключа шифрования по PIN
(IOS SecureEnclave)
[27] Шифрование refresh token
Сохранить данные в защищенном хранилище
[28] • refresh token (encrypted)
• метаданные шифрования
[29] Сохранить в памяти
• access token
[30] Сохранить метаданные
• refresh token expiration
Front
Auth Gateway
Device Binding Service
User Service
KeyCloak